言行 银行 AI 智能体安全自评报告

项目全称：言行——融合任务规划与分级授权的多场景银行 AI 智能体

速发贝团队　安全自评报告　提交版 1.0　2026 年 11 月 1 日

本报告评估言行 2.0.0 在 Windows 本机单用户、虚构银行数据和模拟资金范围内的安全控制。模型没有付款授权，身份、权限、TOTP、幂等、资金一致性、持久恢复与审计由可信程序处理。结论只覆盖已执行检查，不构成真实银行、生产安全或第三方合规认证。

本版对应 2026 年 11 月 1 日的提交快照，源码基线 e555721b 及已验收修订，精确版本由源码包内 SHA256 清单确定。本人手机现场签收、第二家在线模型、独立新电脑及 200%真实桌面缩放未完成验证，均列为已知验证边界。

1 资产与信任边界

保护资产包括模拟资金、流水、订单、卡片、订阅、风险档案，以及账号口令、会话、TOTP 密钥、恢复码、模型密钥、操作挑战、计划与审计。业务数据虽为虚构，授权和恢复仍按明确状态实现，防止重复付款、越权和伪造成功。

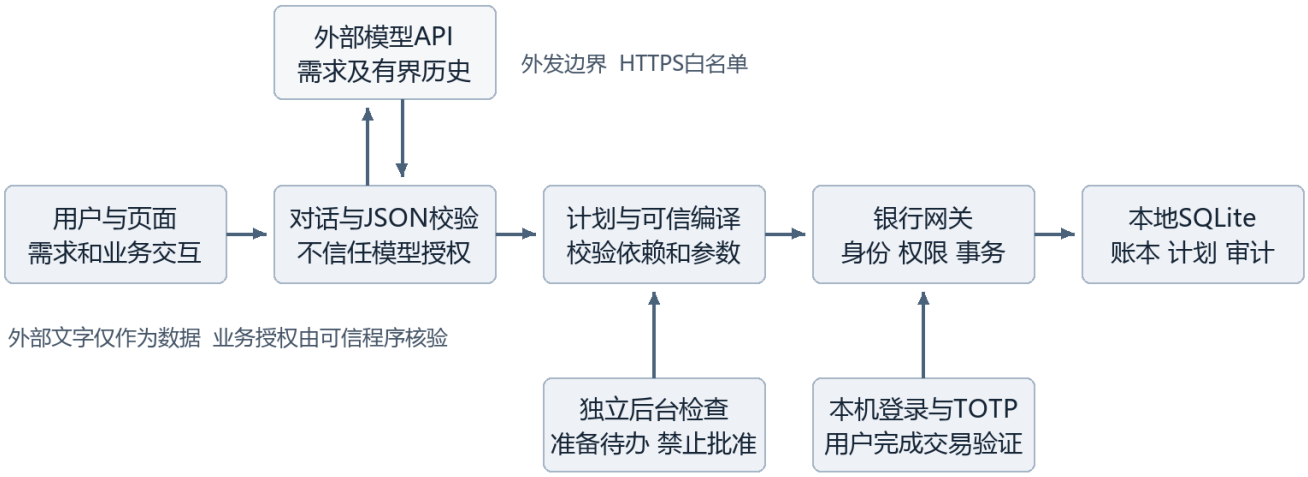


图 1 模型交互与可信业务执行的关系

边界	进入的数据	可信侧处理
用户输入到规划层	自然语言 修改指令 业务字段	限长 槽位约束 缺项澄清 不生成授权
模型服务到客户端	HTTP 响应 JSON 及模型文字	地址与结构校验 闭集动作 限制大小和深度
计划到银行网关	编译后的业务请求	身份 归属 权限 摘要 幂等与执行前重验
手机验证器到认证服务	TOTP 动态码	时间窗 防重放 失败锁定 会话与挑战绑定
后台到执行层	到期任务和原操作状态	租约互斥 原键恢复 禁止后台批准交易

边界	进入的数据	可信侧处理
程序到本机存储	账本 计划 密钥与审计	事务 DPAPI 或摘要存储 依赖本机权限保护

自然语言、模型输出、商户名称和订阅依据均视为不可信数据。信任来自程序当前读取的身份、资源和账本，而非模型宣称“用户已确认”。本机操作系统账户及程序文件完整性属于前提；攻击者若已控制同一 Windows 用户进程，就可能读取内存或修改本地文件，应用不能宣称抵御这种完全主机失陷。

2 身份认证与账号恢复

2 1 首次设置与密码会话

首次可选择体验示例账户或设置本机账号，共用示例账本，体验验证明确标注。设置只建一个本地用户，映射当前模拟身份；要求回环监听及有效 Host，不能单靠请求头伪造入口。设置后必须完成恢复码保存确认和手机绑定，已有账号不能降级体验，并发初始化不能覆盖账户。

密码长度为 12 至 256 字符，不保存明文；使用 16 字节随机盐和 scrypt，参数为 N 等于 32768、r 等于 8、p 等于 3，派生长度 32 字节。校验使用恒定时间比较。会话使用随机令牌，数据库只保存 SHA256 摘要，当前有效期 3600 秒。连续 5 次密码错误锁定 600 秒。

这是本地单用户身份体系，没有完成企业级多租户隔离、管理员角色分工或远程身份联邦。密码登录只建立会话，不等同于对某笔交易授权；红色业务还需要当前操作的有效动态码证明。

2 2 TOTP 与交易证明

验证器密钥由程序生成并用 Windows DPAPI 加密保存。动态码为 6 位、30 秒一步，允许当前及前后一步，通过已消费步防重放。绑定与交易使用实际算法；绑定会消费相应码，不能立即重复用于交易。

TOTP 连续 5 次错误触发 600 秒锁定；每个交易挑战另有失败次数控制，累计 5 次错误会锁定本次操作。两种锁定和模型会话异常熔断分别维护，重新打开页面或输入“继续”不能解除服务器侧交易锁定。

真实验证模式下，挑战使用 v1.2 和 totp 方法，验证成功产生一次性证明，数据库保存证明摘要并绑定当前会话。后台和真实验证模式不能签发演示凭据。成功登录、更换页面或恢复计划不自动产生新证明，过期或状态变化后须重新核对。

2 3 恢复码与更换手机

首次设置生成 8 个随机恢复码，用户须离线保存并确认。确认前，为支持中断续接，整组材料经 DPAPI 暂存；确认后删除可完整显示的暂存内容，后续核验使用逐码摘要。报告、日志和参赛附件不能携带恢复码或二维码中的种子。

更换手机须正确密码加一个未使用恢复码。成功后消耗该码，撤销旧会话与旧绑定，再要求重新绑定。恢复不是付款授权，也没有绕过密码的重置入口。密码和恢复码同时丢失时，当前流程没有承诺自动找回能力，不能把删除数据库或重置账号当成正常业务恢复。

自动化使用临时账户和真实 pyotp 算法验证设置、失败、锁定、重放及恢复；用户本人手机尚未完成实际验收，因此结论限定为实现与自动化通过。

3 业务权限与授权绑定

等级	主要动作	授权要求
绿色	余额 收款人解析 流水 原操作查询 账单分析 产品对比 日期计划	仍校验输入与资源归属 允许范围内查询可直接执行
绿色写入	wealth.assess 风险评估	完整问卷及幂等控制 会保存档案 AI 入口仍须准备
黄色	日累计含本次不超过 1000 元转账 AA 建单 卡申请 订阅查看识别核实排除取消提醒 预算预留释放	明确显示对象及内容 由用户确认
红色	超过 1000 元转账 理财申购赎回 卡限额与状态操作 商户下单 每期订阅续费	有效且匹配的强验证证明 普通确认不能替代
动态	定时转账登记及到期付款	分别按当前流程计算 到期重新授权

权限由 shared/policy.py 和网关计算，模型不能自行声明绿色、降低阈值或填写确认状态。转账门槛为 100000 分，含本次等于门槛仍为黄色，超过才为红色；依据为同一用户跨付款账户的上海执行日累计，执行时处理并发及等待期间的变化。

授权摘要绑定接口版本、用户、动作、规范化参数和幂等键；该摘要用于对应关系校验，本身不是数字签名或用户同意证明。挑战有效期 10 分钟，还绑定收款人或相关资源。用户确认时重新检查归属、状态、余额、限额、风险匹配和产品条件。

若原黄色挑战等待期间因累计变化升级为红色，网关取消旧确认挑战并要求强验证，不能沿用较低等级许可。拒绝、过期、已用、锁定或资源变化都不能被模型文字覆盖。定时登记也不能形成永久付款许可。

4 模型 API 与密钥安全

4 1 地址约束与服务商隔离

当前支持五家服务商配置，外部请求限制为预设 HTTPS 主机和路径，服务商必须与地址一致；拒绝 URL 用户信息、查询参数、片段及不合规端口，禁用 HTTP 重定向。这些控制减少错误配置把密钥发送到其他地址的风险，但不能代替对服务商自身安全和数据政策的评估。

代码另允许受约束的回环 HTTP 兼容地址，供本机服务使用。该入口不等于已经安装并验证本地模型，亦不保证同一机器上的所有服务可信。远端地址不能借此退化为任意 HTTP 地址。

已保存配置 v2 绑定服务商。页面切换服务商会清理未保存密钥，持久化切换不能沿用上一家服务商的加密密钥。保存前验证失败保留原配置，采用临时文件替换降低部分写入风险。路径还检查符号链接和硬链接等不安全形态。现有设计只保存一份当前配置，不应宣传为多账户密钥管理平台。

4 2 凭据与外发数据

API 密钥静态保存使用当前 Windows 用户的 DPAPI，运行时在内存中解密。加密失败时不回退明文磁盘保存。环境变量配置本身不自动获得 DPAPI 保护，导出环境或分享终端日志时仍可能泄露；同一用户权限下的恶意进程也不在 DPAPI 的隔离承诺内。

请求会携带业务需求及有界历史。自由输入可能包含用户自行填写的敏感资料，当前没有可以证明覆盖所有情况的自动脱敏能力，也没有证明供应商侧不留存数据。演示只使用虚构资料，不将密码、动态码、恢复码、验证种子或模型密钥输入 AI 对话。

客户端仅保留受限调用元数据，并将 HTTP 错误映射为受控提示，避免直接显示远端原始错误。源码中的不记录设计不等于所有系统级日志天然安全，交付前仍需检查截图、终端记录和打包文件。

4 3 协议与资源控制

请求最大 64KiB、响应最大 256KiB，默认 45 秒超时，禁止自动重试和自动跨服务商切换。消息数为 1 至 40 条，输出须通过外层响应与正文 JSON 校验；截断、非预期模型标识和工具调用结构不能直接进入业务执行。模型 ID 的本地格式校验并不证明远端支持。

2026 年 10 月 28 日归档的 DeepSeek 复验，按“白金卡”名称完成冻结和解冻两次页面操作，经临时身份 TOTP 验证，刷新未重复调用；不等于本人手机签收。原 5 元测试账本累计 20 次、预留 5 元，用量估算上界 0.097314 元，非实际扣费。历史在线记录保留原版本，不合并成当前全场景成功率；其他四家未在线复验。

5 提示注入与计划执行控制

模型只返回声明式 JSON，不运行模型生成的 Python、SQL、Shell 或任意插件代码。动作与字段采用闭集约束，可信编译器拒绝身份、权限、验证证明和风险分数等受保护字段，再将允许的业务意图映射到既有接口。商户名称中的指令和模型回复中的“已付款”都只是数据。

计划最多 20 步，编号与依赖图校验在规划和执行入口重复实施。依赖必须存在且无环，跨步骤资源引用必须来自成功前置祖先回执。计划修订保留已完成步骤和原操作键，不允许通过删除或改号把已付步骤变成新的待付款。

输入需求最长 1000 字符，草稿最长 30000 字符，JSON 深度最大 16、节点最大 4096，并拒绝重复键。对话历史默认 12 条、上限 32 条，累计序列化文本不超过 24000 字符；连续 5 次异常草稿停止当前会话。上述边界降低资源耗尽和非法结构风险，但没有证明能识别所有提示注入文本。

项目采用逻辑隔离和受控动作执行，没有独立操作系统沙箱。安全依据是模型无任意执行接口且实际业务仍受网关限制，不应描述成“可安全执行任意模型代码”或“完全免疫注入”。

6 资金 幂等与故障恢复

模拟资金使用整数分，费用和份额使用 Decimal，保持余额等于可用加预留。所有付费动作遵守已有业务校验，相关资金、订单、流水、回执和审计通过事务或保存点关联；失败时按事务边界回滚，不以页面显示成功作为入账证据。

操作键绑定用户、动作和请求；同键同内容重放原回执，同键改参拒绝。回执丢失后保留原操作并查询，不自动换键重付。未决业务旁可继续提问、澄清、修改草稿和执行纯查询；新写操作仍按原冲突与授权检查。unknown 原请求、原键、资金占用及已保存原计划保持，不能靠刷新或清草稿消除。订阅读取仍需黄色确认，真实红色业务仍需当次动态码。

计划快照包含受控任务、依赖、修订号、操作关联及回执，并与事件在同一事务保存。保存使用乐观版本检查，旧页面不能静默覆盖新状态。恢复不保存完整聊天、密钥或验证凭证，也不会把登录恢复等同于付款批准。

预算释放必须依据已核实的剩余可用预留。订单未知时，不能只因为暂时没有查到订单就释放资金，或创建一个新键再尝试付款。这是项目明确保留的安全停点，宁可等待核实，也不推断未发生资金变化。

本地 SQLite 提供当前演示所需事务一致性，但未提供跨机构清算、分布式账本一致性或生产级数据库高可用保证。直接修改本机数据库不在业务接口防护边界内。

7 后台任务与生命周期安全

后台由用户主动启用，采用独立进程、数据库租约和心跳避免多个进程重复领取任务。后台可以检查定时事项、准备确认或验证请求、恢复原操作及写入站内通知，但网关明确拒绝后台批准交易。后台不会在每次检查中调用付费模型。

停止后台后不再领取新任务，已经开始的处理允许结束，未决结果继续保存。页面关闭不等于后台停止，正常退出由程序协调停止后台及页面服务，显式停用与保留启动偏好的退出有不同含义。状态展示区分正在启动、运行、停止以及心跳等实际信息，不能仅凭进程创建请求就宣称运行正常。

生日自动检查可以准备月度预算和采购时点待办，但没有长期无人值守付款许可。金额、对象和日期发生变化仍需按既定规则核对；电脑关机、应用未启动或后台未启用时，不承诺任务会按时执行。通知为本地站内记录，无短信、邮件或系统推送。

服务只面向本机回环。安装版默认 8511 端口、数据在%LOCALAPPDATA%\言行\data，与源码版 runtime 分开；用户自行配置账号及密钥。安装包未包含开发机身份、TOTP 种子或模型密钥。此范围不扩展为公网多用户认证和运维结论。

8 审计与可追溯性

银行审计记录操作、挑战和结果，计划事件记录草稿处理、修订、暂停、恢复与步骤推进等受控事件，可信程序生成跟踪号关联两侧。事件采用闭集字段，避免把自由对话或未约束模型文本直接当作审计内容。API 密钥、动态码和证明令牌不应写入这些事件。

审计失败时停止新的计划推进；已经提交的交易仍保留原事实，不能因为展示或审计后续失败就重新执行。计划持久化让恢复可以定位原版本和操作，但不保证任意历史日志都能重建成完整用户对话。

SQLite 文件中的审计没有远程只追加存储、可信时间戳或独立签名链。拥有本机文件修改权限的人可能改动账本和日志，因此当前审计主要用于本地演示追溯、故障核实和测试，不能作为不可抵赖的外部证据。

9 STRIDE 威胁评估

以下按身份冒充、篡改、抵赖、信息泄露、拒绝服务和权限提升六类组织风险。评估描述当前使用边界下需要关注的事项，不是第三方评分；控制有效性以现有测试覆盖为限。

威胁类别	代表性路径	已实施控制	残余边界
身份冒充	伪造用户或复用动态码	密码会话 TOTP 防重放 恢复撤销 网关身份核对	同一 Windows 用户进程失陷不能靠本地认证隔离
数据篡改	改付款参数 改已执行计划 伪造依赖	摘要绑定 执行重验 幂等冲突 修订号及依赖检查	本机源码或数据库直接被改仍有风险
操作抵赖	否认授权或删除历史	挑战 操作与计划事件关联 原键回执	无独立签名或远程不可变审计
信息泄露	密钥误发 模型历史外发 日志泄密	地址白名单 服务商绑定 DPAPI 受控错误与事件字段	自由输入与供应商侧留存未全面控制
拒绝服务	巨大响应 深层 JSON 请求挂起	大小 深度 节点 超时及异常会话限制	无公网配额防护 高并发压力尚未验证
权限提升	模型伪造确认 后台代付 旧会话批准	闭集动作 服务端分级 挑战绑定 后台禁批准	依赖可信本机程序 不允许任意代码执行

10 验证结果与可复核证据

2026 年 11 月 1 日提交前完整离线回归 713 项通过，0 失败、0 错误；另 15 项安装工具离线测试通过。使用独立临时模拟数据库，不新增真实银行、本人手机或付费模型验证。历史阶段的结果和安全发现按日期分别保留，不与本轮计数相加。

证据	实际结果	范围与限制
2026-11-01 源码复核	713 项完整离线回归通过	临时模拟数据库；不调用真实模型 HTTP
安装工具复核	15 项安装工具用例通过	独立于 713 项；不替代真实安装检查
2.0.0 历史安装验收	真实构建、覆盖升级、数据保留与启停已通过	2026-10-28 记录；未签名，独立新电脑未验
模型在线证据	DeepSeek 有分版本真实在线记录	其他四家仅离线接入验证；不推定五家在线通过
本人手机与生产环境	本人现场签收、第二家在线模型等尚未完成	临时身份 TOTP 不等于本人手机；不作生产认证

本轮复核日志和文件清单随源码包保存。2.0.0 的实际安装、覆盖升级与数据保留证据来自 2026 年 10 月 28 日；旧阶段的失败、修复和通过记录保留原覆盖范围，不直接外推为当前全部环境已通过。

控制领域	代表性测试源码	结论解释
API 边界与密钥	tests/test_model_providers.py 与 test_model_settings_acceptance.py	验证本地协议 配置和拒绝路径 不代表真实服务商可用
模型与计划安全	tests/test_model_security.py 及模型计划相关测试	所列结构 注入和伪造输入被限制 不承诺全部攻击覆盖
授权与恢复	tests/test_gateway.py test_recovery.py	校验身份 挑战 幂等和未知结果边界
首次设置与用户流程	tests/test_u1_setup.py test_u2_flows.py	临时身份和实际算法验证 不替代本人手机验收
后台与启动退出	tests/test_u3_background.py test_u4_launcher.py	覆盖本机进程及租约流程 不代表系统服务或全新机器安装

这些测试证明所列场景在记录的版本和环境下符合断言。通过数量不能转换为安全百分比，历史 9 组 11 次模型调用也不能算作第三方渗透测试。对新增攻击思路或变更后的协议，应补充对应验证后再更新结论。

11 剩余风险与提交边界

事项	当前状态	后续最低验证
新增四家真实 API 调用	本地实现与离线测试完成 在线未验收	使用获授权额度与虚构数据 记录模型和实际请求结果
用户本人手机验证	临时身份自动化完成 本人未签收	本人绑定 登录 红色模拟业务 错误码与恢复体验
完全主机失陷	依赖 Windows 账户和文件权限	若扩大部署范围 重新设计主机与服务隔离
外发隐私与第三方留存	模型会接收需求及历史 无全面自动脱敏证明	真实资料使用前明确字段范围 留存与脱敏策略
公网和多用户部署	不在当前已验收范围	独立评估远程认证 角色 隔离 限流和运维
独立安装与跨机器复现	2.0.0 本机临时目录安装、升级、启停、卸载和数据保留检查通过	安装器未签名；独立新电脑和更多 Windows 版本未验
长期无人值守付款	未实现亦未默认授权	先确定额度 期限 撤销和变更规则再另行设计

报告可支持本机模拟演示范围内的参赛说明。不得写成已经接入真实银行、通过生产合规认证、完成全部服务商在线验收或能够无人值守付款。若未来采用真实客户资料或开放远程访问，本报告的威胁前提和结论需要重新评估。

12 依据与更新规则

身份与授权依据为 bank/auth.py、bank/first_run.py、bank/gateway.py、shared/contracts.py 和 shared/policy.py。模型边界依据为 agent/model_client.py、agent/model_credentials.py、agent/model_providers.py、agent/model_dialogue.py、agent/model_safety.py 和 agent/model_bank.py。持久化与后台依据为 bank/plan_store.py、bank/store.py、bank/worker.py、bank/background.py 和 bank/lifecycle.py。

当前 713 项完整离线回归与 15 项安装工具检查见本次源码包验收记录。历史 DeepSeek 在线、离线以及 2.0.0 安装证据分别按原时点解释；回归通过不等于第三方渗透、独立新电脑或生产部署已验证。

后续若改变模型接口、外发上下文、身份机制、权限阈值、挑战有效期、密钥保存、后台能力或恢复策略，应同步修订本报告并重跑受影响测试。仅文字和版式变化可做材料校验；行为变化不能只改结论而不取得新证据。

13 最新验证与安装交付

本版保留可信原操作的授权级别与执行状态分开展示。未决业务旁可继续提问、澄清、修改草稿和执行允许的纯查询；新写操作仍按冲突与授权检查。unknown 原请求、原键、资金占用和已保存计划不被刷新或清草稿消除。订阅读取需确认，真实红色业务仍需当次动态码。

AUD-06 已修复：未改变的可信执行时间、已完成事实与操作键保持；预算金额修订保留自定义时刻，冲突时拒绝新草稿并保留原计划。历史确定性复现仍留存追溯。

AUD-07 已修复：旧 worker 失去所有权后不再推进新业务。停止状态结合实例退场记录核验，租约过期或审计不可读时显示待核实；已发出的原操作仍按原编号查询。

定时转账备注已补齐：共享契约增加与单笔转账同义的可选 memo，登记、固定到期请求、可信核对、执行与原操作恢复保持一致。旧无备注请求与已登记任务兼容；同幂等键改备注拒绝，不修改付款阈值或授权规则。

提交前 713 项完整离线回归及 15 项安装工具用例通过。2.0.0 历史另有 5 项干净启动/后台检查、18 项当期安装工具检查，以及 22 种展示状态、108 次业务块检查。用例总数不等于安全覆盖率或业务成功率，也不证明不存在未发现漏洞。

已归档的 DeepSeek 页面验证使用临时身份完成卡片冻结与解冻，并校验刷新未重复调用；它不等于本人手机签收，也不证明其他四家服务商或当前全部场景重新在线通过。本次提交材料整理未调用新的付费模型服务。

当前安装交付为 Windows x64 2.0.0，已完成本机实际构建、安装和覆盖升级、启停、卸载及数据保留验证。随包安装器保留已验收字节，未做发布者代码签名；独立新电脑和全部 Windows 版本尚未验证。当前源码及材料以本次指纹为准，答辩材料已提供，演示视频暂不提交。